

ACTIVITY PACK

Activity 4: Skill Plugin Risk Review

Activity 4 - Rogue Agent Post-Incident Review

Course	AI Security for Autonomous AI Agents
Course code	TGS-2025060473
Version	2.1 20 August 2026

Tertiary Infotech Pte Ltd | UEN 20120096W

Skill Plugin Risk Review

Activity 4 - Skill, Plugin and MCP Supply-Chain Review

Assume an autonomous coding agent recommends a community skill called `secure-cloud-audit`, delivered with a `SKILL.md`, two shell scripts and an MCP server package. The marketplace page claims it can "auto-remediate every cloud finding" and asks for cloud-admin credentials.

Evidence request

Area	Questions	Evidence
Provenance	Who owns and maintains it? Is the name a near match? Has ownership changed?	Publisher identity, repository history, licence
Integrity	What exact content will run? Can the release change after review?	Pinned commit/version, checksum/signature, unpacked source
Capabilities	Which tools, files, commands, hosts and cloud APIs are reachable?	Manifest, scripts, tool schemas, permission diff
Credentials	Which secrets are requested and how are they passed?	Secret broker policy, short-lived role, redacted test log
Network	Where can it connect and what data can leave?	Destination allowlist, DNS/HTTP logs, egress policy
Isolation	What prevents host or cross-project access?	Non-root sandbox, read-only mounts, workspace boundary
Approval	Who approves install, update and consequential actions?	Change ticket, canonical action preview, expiry
Operations	How is it monitored, disabled, rolled back and offboarded?	Inventory, alerts, rollback test, identity revocation

Safe review exercise

1. Do not install the package.
2. Identify every claim that requires independent evidence.
3. Flag the request for cloud-admin credentials as excessive and replace it with a narrowly scoped, short-lived read-only role for assessment.
4. Define the minimum test sandbox and outbound allowlist.
5. Decide whether auto-remediation is ever permitted. Separate reversible tagging from changes to identity, firewall, encryption, retention and deletion.
6. Write the condition that blocks autonomous installation: an agent may recommend a component, but a human change owner must verify and approve the exact pinned artefact.
7. Define re-review triggers: publisher, version, dependency tree, permissions, tool schema, network destinations or ownership changes.

Decision record

- Decision: approve / approve with conditions / reject.
- Exact version or commit:
- Permitted capabilities:
- Prohibited capabilities:
- Approver and expiry:
- Monitoring owner:
- Rollback and revocation evidence: